



Day Shift – Security Posture Summary

Last updated: June 2026 · app.dayshiftnow.me

Architecture

Browser / Mobile → **HTTPS** (TLS 1.3) → **FastAPI** (Python) → **Neon PostgreSQL**
(encrypted at rest)

Payments: never touch our servers – handled entirely by **PayPal** via
Orders API v2

Email: outbound via **Resend**, inbound webhooks signature-verified (svix)

Security Controls

Authentication	JWT-based (HS256), bcrypt password hashing, 7-day session expiry, optional reCAPTCHA on register/login
Authorization	Role-based (admin / worker / employer). Ownership verified on every mutation (videos, boosts, matches, messages, subscriptions). Admin routes require explicit admin role check.
Data isolation	Multi-tenant queries scoped by user ID at the database layer. Cross-user data access prevented via JOIN constraints (e.g., messages require match participation).
Secrets management	All credentials injected via environment variables. No hardcoded secrets. No .env files committed. JWT signing key validated at startup – refuses to start if missing.
Payments	PayPal Orders API v2. Credit card data never enters our infrastructure. PayPal webhook endpoint exists; production capture happens client-side after PayPal redirect.

Webhook security	Inbound email webhooks verified via svix HMAC-SHA256 signatures (Resend). Stripe webhooks verified via Stripe SDK signature validation.
SSRF protection	All outbound HTTP fetches (URL import, link preview) validate destination: block localhost, loopback, private ranges (10.x, 172.16.x, 192.168.x), link-local (169.254.x), multicast, IPv6 loopback.
Input validation	Server-side text sanitization with length limits. File uploads capped at 10 MB (images) / 100 MB (video). Video duration enforced server-side via ffprobe.
Rate limiting	Auth endpoints rate-limited. File upload quotas per user.
Transport security	HTTPS-only (TLS 1.3). HSTS enabled. CORS restricted to known production and development origins.
Logging & monitoring	Structured logging (stdout). Sentry for error tracking. PostHog for product analytics (anonymous usage, not PII).
Data retention	User data retained for account lifetime. Deleted on account closure. Suspended accounts auto-unsuspended on expiry. Backup via Neon automated snapshots.

Third-Party Subprocessors

Neon	PostgreSQL hosting (AWS us-east-2)
PayPal	Payment processing
Resend	Transactional & inbound email
Sentry	Error monitoring
PostHog	Product analytics (optional, anonymous)
Google reCAPTCHA	Bot protection on auth forms

Certification status: Day Shift is built with SOC 2 and ISO 27001 principles in mind but has not undergone formal third-party certification at this stage. We are happy to complete your organization's security questionnaire.

Day Shift · contact@dayshiftnow.me · app.dayshiftnow.me